

QUIZ ANSWER CHEAT SHEET

Sprint 2 — Engineering Practices: Agile, SRE & Cyber

20 questions • Source: Sprint2-Westlake.xml

1. A Product Owner brings a backlog item to refinement that reads "Improve the mobile app's performance." The team can't estimate it, can't agree what "done" looks like, and it clearly bundles several unrelated pieces of work. Using the INVEST criteria, which criterion is this item most clearly failing, beyond simply being "too big"?
 - ✓ Small and Estimable — it bundles unrelated work and has no clear scope, so the team can't size it with any confidence
2. While reviewing a backlog, you spot an item titled "Migrate the reporting service's database to a new schema version," written in story format with a "so that" clause added to make it look like a user story. Which of the following are genuine concerns with treating this the same way as a normal user story during sprint planning? (Select all that apply.)
 - ✓ It's really a technical initiative dressed up as a story, which can obscure that it needs different sizing than customer-facing work
 - ✓ Its "value" is indirect (enabling future work or reducing risk) rather than a direct customer-facing benefit, which INVEST's "Valuable" criterion doesn't capture well for this kind of item
 - ✓ Forcing it into user-story shape can hide risk and sequencing conversations (e.g. rollback plans, downtime) that a normal feature story wouldn't need
3. During a Planning Poker session, votes for a story come back as 2, 3, 3, 8, 13, a wide spread. What is the recommended next step, rather than just averaging the numbers?
 - ✓ Have the highest and lowest voters explain their reasoning, then re-vote, since the spread usually means people are assuming different scope or risk
4. A team is set a capacity of 30 person-days for a sprint and estimates a set of stories in points, using a rough rule of thumb of roughly 1-2 person-days per point. After totalling the estimates, several lower-priority stories don't fit. Which of the following reflect good sprint planning practice in this situation? (Select all that apply.)
 - ✓ Leave the lower-priority stories out of this sprint rather than forcing them all in
 - ✓ Write a sprint goal that still holds true even if one of the included lower-priority stories has to be dropped mid-sprint
 - ✓ Discuss the trade-off with the Product Owner so the deprioritised stories are a deliberate, understood choice rather than a surprise
5. You open a PR with a commit titled "fix: correct off-by-one error in pagination". Which of the following best describes why this follows the Conventional Commits convention correctly?
 - ✓ It uses a recognised type prefix (fix) followed by a colon and a concise description of the change, matching the : convention
6. Two colleagues each branch from the same commit on main and both change the same line in a shared config file to different values. The first PR merges cleanly. When the second tries to merge, GitHub reports a conflict. What is the correct way to resolve it?
 - ✓ Pull the now-updated main into the second branch locally, resolve the conflict in the file by removing the markers and choosing the agreed content, commit, and push — the PR will then show as mergeable
7. A repository's main branch has branch protection configured to require a PR and at least one approval before merging. Which of the following statements about this setup are correct? (Select all that apply.)
 - ✓ A developer with local write access who tries to push a commit directly to main will have that push rejected
 - ✓ A change can only reach main by going through a reviewed, approved PR
 - ✓ Branch protection applies regardless of who is pushing, unless the repository is specifically configured to allow admins to bypass it
8. You're reviewing a colleague's PR and notice a hardcoded database password in a config file they've added. Following good code review etiquette, which comment best balances being specific and constructive rather than just critical?
 - ✓ "This password looks hardcoded — could we move it to a secrets manager or environment variable instead, so it isn't committed to source control?"
9. You receive a review comment on your own PR that you disagree with. Which response best reflects the non-defensive approach to receiving feedback covered in this sprint?
 - ✓ "I chose this approach because of X — does that address your concern, or is there something I'm missing?"
10. A Jenkins pipeline runs Checkout, Build, Test, Acceptance Test, and Security Scan stages in order. The pipeline fails at the Security Scan stage, which runs a dependency scanner reporting one CRITICAL severity vulnerability in a third-party library, against a configured threshold of zero CRITICAL findings. Which of the following statements accurately explain why the pipeline stopped rather than proceeding to deploy? (Select all that apply.)
 - ✓ A known critical-severity vulnerability was found in one of the application's dependencies
 - ✓ The pipeline is configured with a threshold of zero CRITICAL findings, and this scan exceeded that threshold
 - ✓ The pipeline is designed to fail the build rather than deploy code carrying an unaddressed critical-severity risk
11. A repository's main branch requires this security-gated pipeline to pass before a PR can be merged. A teammate asks: "what would have actually happened if we'd merged this change anyway, bypassing the failing scan?" What's the correct answer, given how branch protection and the pipeline are wired together?
 - ✓ The merge itself would have been blocked, since branch protection requires this specific pipeline's status check to pass first — the failing scan is what prevents the vulnerable dependency from reaching main
12. You're refactoring a single-stage Dockerfile into a multi-stage build for a Java service. The build stage starts FROM maven:3.9-eclipse-temurin-21 AS build and compiles the jar; the runtime stage starts fresh FROM eclipse-temurin:21-jre-alpine and copies in only the built jar. Which statements correctly explain why this typically produces a noticeably smaller final image than the

single-stage version? (Select all that apply.)

- ✓ Only the artifacts explicitly copied with COPY --from=build (here, just the jar) make it into the final image
- ✓ The final image is built from a JRE-only base, so none of the Maven build tooling or JDK compiler used by the build stage is carried into it
- ✓ A smaller final image also has the side benefit of a reduced attack surface, since unnecessary build tools aren't shipped to production

13. A docker-compose.yml defines an app service (build: ., no ports: mapping) and a db service (postgres:16-alpine image, with ports: "5432:5432"). After running docker compose up -d, which of the following statements correctly describe what's reachable, and from where? (Select all that apply.)

- ✓ The db service is reachable from the host machine on localhost:5432, because it has an explicit port mapping
- ✓ The app service is not reachable from the host machine at all, since it has no ports: mapping defined
- ✓ The app service is reachable from the db container (and vice versa) on the compose network, using the service name as a hostname

14. After running docker compose down -v on a stack with a named Postgres volume, a colleague asks why the database came back completely empty the next time they ran docker compose up -d, when a plain docker compose down (without -v) hadn't caused this before. What's the correct explanation?

- ✓ The -v flag additionally removes named volumes, including the one holding Postgres's data directory, so the database starts fresh with no prior data; without -v, the volume (and its data) persists across down/up cycles

15. You're reading a Terraform configuration for the first time and comparing it to writing an equivalent set of AWS CLI commands in a shell script. Which of the following correctly capture why the Terraform file is described as declarative rather than imperative? (Select all that apply.)

- ✓ The Terraform file describes the desired end state of the infrastructure, rather than the steps to get there
- ✓ An equivalent CLI script would need to explicitly handle checking current state, correct ordering, and what to do if a resource already exists — logic the declarative file doesn't need to spell out
- ✓ Terraform itself works out what needs to change to reach that desired state, rather than the author scripting each step

16. A team's CI/CD pipeline runs terraform plan automatically on every PR, but terraform apply requires a manual approval step before it runs. Why might a team deliberately require a human approval before apply specifically, when they don't require one before a routine application code deploy?

- ✓ Infrastructure changes can be higher-risk and harder to reverse than an application deploy (for example, changes affecting data storage, networking, or access controls), so a human reviewing the planned change before it's applied adds a deliberate safety check

17. You're reviewing a data access method that builds a SQL query by directly concatenating a caller-supplied merchant name into the query string: "SELECT * FROM transactions WHERE merchant_name = '" + merchantName + '". Which of the following statements about this code are correct? (Select all that apply.)

- ✓ A malicious merchantName value could alter the query's logic or expose data the caller shouldn't be able to see
- ✓ This is a classic SQL injection vulnerability, since the caller-supplied value becomes part of the query's own syntax rather than staying pure data
- ✓ Using a parameterised query, such as a PreparedStatement with bind variables, is the standard fix, since the driver keeps the supplied value as data and never merges it into the SQL text

18. A registration service "hashes" passwords using MD5 before storing them, with a comment noting this as the hashing step. Which of the following statements correctly explain what's wrong with this approach? (Select all that apply.)

- ✓ MD5 is a fast, general-purpose hash, and that speed makes brute-forcing large numbers of password guesses practical
- ✓ Without a per-password salt, identical passwords hash to identical values, making precomputed lookup tables (rainbow tables) effective against them
- ✓ A slow, salted, purpose-built password-hashing algorithm such as bcrypt or Argon2 should be used instead

19. An endpoint accepts a customer-supplied imageUrl parameter and fetches it server-side to set as the customer's profile picture, with no restriction on what URL can be supplied. A colleague asks what's risky about this if a customer supplied an internal URL like http://169.254.169.254/latest/meta-data/ instead of a real image link. What's the correct explanation and fix?

- ✓ This is Server-Side Request Forgery: the server can be tricked into making requests to internal-only resources (like a cloud metadata endpoint) on the attacker's behalf, so the fix is to validate/allow-list the target host before fetching, not just check that the URL "looks like" an image link

20. A service has an SLO of 99.9% availability over a rolling 30-day window (43,200 minutes total). Over the last 30 days it recorded a total of 51.5 minutes of downtime, concentrated almost entirely in a single incident rather than spread evenly. Which of the following statements are correct? (Select all that apply.)

- ✓ Actual downtime of 51.5 minutes exceeds the 43.2 minute budget, so the SLO has been breached
- ✓ The error budget for this SLO is 43.2 minutes (0.1% of 43,200 minutes)
- ✓ Because the downtime came from one concentrated incident rather than many small ones, the team should prioritise investigating and fixing that incident's root cause rather than assuming a broad, systemic reliability problem